

ĐẠI HỌC QUỐC GIA THÀNH PHỐ HỒ CHÍ MINH
TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN
KHOA KHOA HỌC VÀ KỸ THUẬT THÔNG TIN



BÀI TẬP THỰC HÀNH 6A (BUỔI 10)
QUẢN LÝ RỦI RO AN NINH
THÔNG TIN

Mã Môn: IE105
Tên Môn: Nhập Môn Đảm Bảo và An Ninh Thông Tin
Lớp: IE105.F22.LT.CNTT
Giảng Viên: ThS. Tô Nguyễn Nhật Quang
Sinh Viên: Đinh Xuân Sâm
Mã Sinh Viên: 25410291

Ngày 19 Tháng 05 Năm 2026

BÀI TẬP THỰC HÀNH 6A — QUẢN LÝ RỦI RO AN NINH THÔNG TIN

Mục Tiêu Bài Thực Hành

Sau khi hoàn thành bài thực hành, sinh viên có thể:

1. Hiểu được khái niệm rủi ro an ninh thông tin.
2. Nhận diện tài sản thông tin (Information Assets) trong bối cảnh thực tế.
3. Xác định mối đe dọa (Threats) và lỗ hổng (Vulnerabilities) tương ứng.
4. Đánh giá mức độ rủi ro dựa trên Khả năng xảy ra (Likelihood) và Mức độ ảnh hưởng (Impact).
5. Đề xuất biện pháp xử lý rủi ro (Risk Treatment) phù hợp theo từng chiến lược.
6. Trình bày báo cáo theo quy trình quản lý rủi ro cơ bản.

Bối Cảnh Được Chọn

Sinh viên chọn **Bối cảnh 3**: Điện thoại thông minh của sinh viên dùng cho mạng xã hội, ngân hàng/ví điện tử và email. Bối cảnh này được chọn vì điện thoại thông minh hiện đại tập trung nhiều loại tài sản thông tin có giá trị khác nhau trong một thiết bị duy nhất, đồng thời phản ánh thói quen sử dụng thực tế của sinh viên.

Cấu Trúc Báo Cáo

Báo cáo được tổ chức theo 6 phần theo quy trình quản lý rủi ro:

- **Phần 1** – Xác Định Tài Sản: Liệt kê và đánh giá giá trị 6 tài sản thông tin.
- **Phần 2** – Xác Định Mối Đe Dọa: Xác định 13 mối đe dọa (≥ 2 per tài sản).
- **Phần 3** – Xác Định Lỗ Hổng: Phân tích lỗ hổng tạo điều kiện cho từng mối đe dọa.
- **Phần 4** – Đánh Giá Rủi Ro: Tính Risk Level = Likelihood $\times$ Impact và phân loại.
- **Phần 5** – Xử Lý Rủi Ro: Chọn chiến lược và đề xuất biện pháp cụ thể.
- **Phần 6** – Nhận Xét & Tự Đánh Giá: Phân tích tổng hợp và rút kinh nghiệm.

LỜI NÓI ĐẦU

Lorem ipsum dolor sit amet, consectetur adipiscing elit, sed do.

LỜI CẢM ƠN

Lorem ipsum dolor sit amet, consectetur adipiscing elit, sed do.

Giảng Viên

Mục Lục

Mục Lục	v
Danh Sách Bảng	vi
Danh Sách Hình Ảnh	vii
Danh Sách Mã Nguồn	viii
Bảng Viết Tắt	ix
1. PHẦN 1 — XÁC ĐỊNH TÀI SẢN (ASSET IDENTIFICATION)	1
1.1. Bối Cảnh Được Chọn	1
1.2. Bước 1 & 2 — Danh Sách Tài Sản Thông Tin	1
1.3. Nhận Xét Chung	2
2. PHẦN 2 — XÁC ĐỊNH MỐI ĐE DỌA (THREAT IDENTIFICATION) .	3
2.1. Bước 3 — Mối Đe Dọa Theo Từng Tài Sản	3
2.2. Tổng Hợp Các Nhóm Mối Đe Dọa	5
3. PHẦN 3 — XÁC ĐỊNH LỖ HỔNG (VULNERABILITY IDENTIFICATION)	6
3.1. Bước 4 — Phân Tích Lỗ Hổng Theo Mối Đe Dọa	6
3.2. Nhận Xét Tổng Hợp Về Lỗ Hổng	7
4. PHẦN 4 — ĐÁNH GIÁ RỦI RO (RISK ASSESSMENT)	9
4.1. Bước 5 & 6 — Ma Trận Đánh Giá Rủi Ro	9
4.2. Bước 7 — Phân Loại Rủi Ro	9
4.3. Lý Giải Điểm Số	10
4.4. Nhận Xét Tổng Hợp	11
5. PHẦN 5 — XỬ LÝ RỦI RO (RISK TREATMENT)	12
5.1. Bước 8 & 9 — Kế Hoạch Xử Lý Rủi Ro	12
6. PHẦN 6 — NHẬN XÉT & TỰ ĐÁNH GIÁ	14
6.1. Bước 10 — Trả Lời Câu Hỏi Phản Chiếu	14
A Thông Tin Về Báo Cáo Này	16
A.1 Mã Nguồn Báo Cáo	16
A.2 Mã Nguồn Nội Dung Chính	16
A.3 Công Cụ Sử Dụng	16

DANH SÁCH BẢNG

Bảng 1	Bảng 1 — Danh Sách Tài Sản Thông Tin (Bối Cảnh 3: Điện Thoại Thông Minh)	2
Bảng 2	Bảng 2 — Mối Đe Dọa Đối Với Các Tài Sản (Bối Cảnh 3: Điện Thoại Thông Minh)	4
Bảng 3	Bảng 3 — Lỗ Hổng Liên Quan Đến Từng Mối Đe Dọa	7
Bảng 4	Bảng 4 — Ma Trận Đánh Giá Rủi Ro ($L = Likelihood$, $I = Impact$)	10
Bảng 5	Bảng 5 — Kế Hoạch Xử Lý Rủi Ro	13

DANH SÁCH HÌNH ẢNH

DANH SÁCH MÃ NGUỒN

BẢNG VIẾT TẮT

Viết Tắt	Nghĩa Đầy Đủ
2FA	Two-Factor Authentication
AES	Advanced Encryption Standard
APK	Android Package Kit
CCMP	Counter Mode with Cipher Block Chaining Message Authentication Code Protocol
CMND	Chứng Minh Nhân Dân
DHCP	Dynamic Host Configuration Protocol
DNS	Domain Name System
FTPS	File Transfer Protocol Secure
HTTP	Hypertext Transfer Protocol
HTTPS	Hypertext Transfer Protocol Secure
IMSI	International Mobile Subscriber Identity
KRACK	Key Reinstallation Attacks
MAC	Media Access Control
MFA	Multi-Factor Authentication
MXH	Mạng Xã Hội
OTP	One-Time Password
PIN	Personal Identification Number
SIM	Subscriber Identity Module
SMS	Short Message Service
SSH	Secure Shell
SSID	Service Set Identifier
TKIP	Temporal Key Integrity Protocol
TOTP	Time-Based One-Time Password
URL	Uniform Resource Locator
VPN	Virtual Private Network
WEP	Wired Equivalent Privacy
Wi-Fi	Wireless Fidelity
WPA	Wi-Fi Protected Access
WPA2	Wi-Fi Protected Access 2
WPA3	Wi-Fi Protected Access 3

Bảng Viết Tắt

CHƯƠNG 1.

PHẦN 1 — XÁC ĐỊNH TÀI SẢN (ASSET IDENTIFICATION)

1.1. Bối Cảnh Được Chọn

Sinh viên chọn **Bối cảnh 3**: Điện thoại thông minh của sinh viên dùng cho:

- Mạng xã hội (Facebook, Instagram, TikTok, Zalo)
- Ngân hàng / ví điện tử (Internet Banking, MoMo, ViettelPay)
- Email (Gmail)

Điện thoại thông minh ngày nay không chỉ là thiết bị liên lạc mà còn là kho lưu trữ tập trung nhiều loại dữ liệu nhạy cảm — từ thông tin tài chính, danh tính cá nhân đến lịch sử giao tiếp. Vì vậy đây là bối cảnh phù hợp để thực hành nhận diện và phân tích rủi ro an ninh thông tin.

1.2. Bước 1 & 2 — Danh Sách Tài Sản Thông Tin

Dưới đây là 6 tài sản thông tin được xác định trong bối cảnh sử dụng điện thoại thông minh, kèm mô tả ngắn gọn và đánh giá giá trị.

STT	Tài Sản	Mô Tả	Giá Trị
1	Tài khoản mạng xã hội (Facebook, Instagram, TikTok, Zalo)	Chứa thông tin cá nhân, danh sách bạn bè, lịch sử hội thoại, ảnh/video cá nhân. Bị xâm phạm có thể dẫn đến mạo danh, lừa đảo người thân hoặc tống tiền.	Cao
2	Tài khoản ngân hàng / ví điện tử (Internet Banking, MoMo, ViettelPay)	Liên kết trực tiếp đến tài sản tài chính. Bị mất quyền kiểm soát đồng nghĩa với nguy cơ mất tiền ngay lập tức và khó thu hồi.	Cao
3	Email cá nhân (Gmail)	Là “chìa khóa chủ” — dùng để khôi phục mật khẩu hầu hết các dịch vụ khác. Nếu bị chiếm, kẻ tấn công có thể kiểm soát toàn bộ danh tính số của người dùng.	Cao
4	Danh bạ liên lạc	Chứa số điện thoại, tên và mối quan hệ của người thân, bạn bè, đồng nghiệp. Dữ liệu này có giá trị với kẻ lừa đảo (social engineering) hoặc spammer.	Trung Bình
5	Ảnh và video cá nhân (Bộ nhớ trong / thư viện ảnh)	Lưu trữ kỷ niệm cá nhân, ảnh nhạy cảm, tài liệu chụp bằng camera (CMND, thẻ ngân hàng, hợp đồng). Rò rỉ có thể gây tổn hại danh dự hoặc tạo điều kiện giả mạo giấy tờ.	Trung Bình
6	Lịch sử trò chuyện (SMS, Messenger, Zalo)	Ghi lại các cuộc hội thoại riêng tư, có thể chứa thông tin nhạy cảm như mã OTP, địa chỉ, kế hoạch cá nhân. Bị rò rỉ ảnh hưởng đến quyền riêng tư và có thể bị dùng để ép buộc.	Trung Bình

Bảng 1: Bảng 1 — Danh Sách Tài Sản Thông Tin (Bối Cảnh 3: Điện Thoại Thông Minh)

1.3. Nhận Xét Chung

Trong 6 tài sản trên, ba tài sản đầu (tài khoản mạng xã hội, tài khoản tài chính, và email) được đánh giá ở mức **Cao** vì chúng gắn trực tiếp đến danh tính, tài sản và khả năng phục hồi các tài khoản khác. Ba tài sản còn lại mang giá trị **Trung Bình** — không gây thiệt hại tài chính trực tiếp nhưng vẫn ảnh hưởng nghiêm trọng đến quyền riêng tư nếu bị xâm phạm. Không có tài sản nào được xếp loại **Thấp** vì tất cả đều chứa thông tin cá nhân có thể bị lợi dụng.

PHẦN 2 — XÁC ĐỊNH MỐI ĐE DỌA (THREAT IDENTIFICATION)

2.1. Bước 3 — Mối Đe Dọa Theo Từng Tài Sản

Với mỗi tài sản đã xác định ở Phần 1, dưới đây liệt kê ít nhất 2 mối đe dọa có thể xảy ra kèm mô tả cụ thể về cơ chế và hậu quả.

Tài Sản	Mối Đe Dọa	Mô Tả
TS1 Tài khoản mạng xã hội (Facebook, Instagram, TikTok, Zalo)	Truy cập trái phép (Account Hijacking)	Kẻ tấn công đánh cắp thông tin đăng nhập qua phishing hoặc brute-force để chiếm quyền tài khoản, sau đó mạo danh nạn nhân để lừa đảo người thân hoặc phát tán nội dung độc hại.
	Lộ thông tin cá nhân qua cài đặt quyền riêng tư sai	Người dùng để hồ sơ và bài đăng ở chế độ công khai, vô tình chia sẻ thông tin địa điểm, thói quen sinh hoạt, số điện thoại — tạo nguyên liệu cho tấn công social engineering.
	Cài đặt ứng dụng giả mạo (Fake App)	Ứng dụng giả mạo Facebook/Zalo được phát tán ngoài kho chính thức. Sau khi cài, ứng dụng thu thập thông tin đăng nhập hoặc đọc nội dung hội thoại trong nền.
TS2 Tài khoản ngân hàng / ví điện tử (Internet Banking, MoMo, ViettelPay)	Tấn công Phishing / Smishing	Nạn nhân nhận được tin nhắn SMS hoặc email giả mạo ngân hàng, dẫn đến trang web nhái thu thập tên đăng nhập, mật khẩu và mã OTP. Kẻ tấn công dùng thông tin này để chuyển tiền.
	Đánh cắp OTP qua SIM Swapping	Kẻ tấn công liên hệ nhà mạng giả mạo chủ thuê bao để chuyển số điện thoại sang SIM mới. Từ đó nhận được tất cả OTP gửi về số đó và vượt qua xác thực 2 bước của ứng dụng ngân hàng.
	Mã độc Trojan trên điện thoại	Phần mềm độc hại ngụy trang thành ứng dụng hữu ích (đèn pin, game). Sau khi cài, Trojan ghi lại các thao tác nhập liệu (keylogger) hoặc chụp màn hình khi người dùng mở ứng dụng ngân hàng.
TS3 Email cá nhân (Gmail)	Tấn công Credential Stuffing	Kẻ tấn công dùng danh sách tên đăng nhập/mật khẩu bị rò rỉ từ các dịch vụ khác để thử đăng nhập vào Gmail. Nếu người dùng tái sử dụng mật khẩu, tài khoản sẽ bị chiếm.
	Truy cập trái phép từ thiết bị bị mất / bị đánh cắp	Nếu điện thoại không có mã khóa màn hình hoặc màn hình không tự khóa sau thời gian ngắn, người có điện thoại trong tay có thể truy cập trực tiếp vào Gmail đang đăng nhập.
TS4 Danh bạ liên lạc	Ứng dụng yêu cầu quyền truy cập danh bạ không hợp lý	Nhiều ứng dụng (game, tiện ích) yêu cầu quyền đọc danh bạ để thu thập và bán dữ liệu liên lạc cho bên thứ ba, hoặc dùng cho mục đích spam và lừa

Bảng 2: Bảng 2 — Mối Đe Dọa Đối Với Các Tài Sản (Bối Cảnh 3: Điện Thoại Thông Minh)

2.2. Tổng Hợp Các Nhóm Môi Đe Dọa

Nhìn chung, các mối đe dọa có thể phân nhóm theo bản chất như sau:

- **Tấn công từ xa** (phishing, smishing, credential stuffing, SIM swapping): Không cần tiếp xúc vật lý với thiết bị, thường nhắm vào tài khoản tài chính và email do giá trị cao.
- **Phần mềm độc hại** (Trojan, fake app, spyware): Khai thác thói quen cài ứng dụng từ nguồn ngoài kho chính thức hoặc click vào đường link lạ.
- **Lỗi cấu hình / thói quen người dùng** (quyền riêng tư sai, không khóa màn hình, tái sử dụng mật khẩu): Tạo cơ hội cho cả tấn công từ xa lẫn tấn công vật lý.
- **Rò rỉ qua bên thứ ba** (ứng dụng lấy quyền danh bạ/ảnh, dịch vụ đám mây): Thường bị bỏ qua nhưng có tần suất xảy ra cao do người dùng ít chú ý đến quyền ứng dụng.

Mỗi nhóm đe dọa trên đều có liên hệ với ít nhất một lỗ hổng cụ thể — sẽ được phân tích chi tiết ở Phần 3 (Xác Định Lỗ Hổng).

CHƯƠNG 3.

PHẦN 3 — XÁC ĐỊNH LỖ HỔNG (VULNERABILITY IDENTIFICATION)

3.1. Bước 4 — Phân Tích Lỗ Hổng Theo Mỗi Đe Dọa

Với mỗi mối đe dọa đã xác định ở Phần 2, dưới đây phân tích lỗ hổng hiện có trong thói quen sử dụng điện thoại thông minh khiến mối đe dọa đó dễ xảy ra hơn.

Mã	Mối Đe Dọa	Lỗ Hổng Liên Quan
T1	Account Hijacking (TS1)	Không bật xác thực 2 bước (2FA); mật khẩu ngắn, đơn giản hoặc tái sử dụng trên nhiều dịch vụ.
T2	Lộ thông tin qua privacy sai (TS1)	Cài đặt mặc định của ứng dụng mạng xã hội thường là “công khai”; người dùng không kiểm tra lại sau khi ứng dụng cập nhật chính sách.
T3	Fake App (TS1)	Thói quen tải APK từ nguồn ngoài kho chính thức (sideloading); thiếu kiểm tra danh tính nhà phát triển và đánh giá ứng dụng.
T4	Phishing / Smishing (TS2)	Nhấp vào đường link trong SMS/email mà không kiểm tra URL; thiếu nhận thức về dấu hiệu nhận biết trang web giả mạo.
T5	SIM Swapping (TS2)	Thông tin cá nhân (tên, ngày sinh, số CMND) bị lộ trên mạng xã hội; phụ thuộc hoàn toàn vào SMS OTP làm phương thức xác thực duy nhất.
T6	Trojan trên điện thoại (TS2)	Cài ứng dụng từ kho bên thứ ba hoặc file APK chia sẻ qua Zalo/Telegram; không bật tính năng Play Protect (Android).
T7	Credential Stuffing (TS3)	Tái sử dụng cùng một mật khẩu cho nhiều dịch vụ; không bật cảnh báo đăng nhập từ thiết bị hoặc địa điểm lạ.
T8	Truy cập thiết bị bị mất (TS3)	Không đặt mã PIN / mật khẩu màn hình khóa; thời gian tự khóa màn hình quá dài (> 5 phút) hoặc bị tắt hoàn toàn.
T9	App quyền danh bạ (TS4)	Cấp quyền tùy tiện khi ứng dụng yêu cầu mà không đọc mục đích sử dụng; không rà soát lại danh sách quyền đã cấp định kỳ.
T10	Đồng bộ cloud không bảo mật (TS4)	Mật khẩu tài khoản Google / iCloud yếu hoặc tái sử dụng; không bật 2FA cho tài khoản cloud.
T11	Rò rỉ qua cloud backup (TS5)	Sao lưu tự động được bật mặc định mà người dùng không kiểm tra nội dung được đồng bộ; ảnh nhạy cảm không được lưu riêng hoặc mã hóa cục bộ.
T12	App chỉnh sửa ảnh độc hại (TS5)	Cấp quyền đọc/ghi toàn bộ thư viện ảnh cho ứng dụng không đáng tin cậy; tải ứng dụng chỉnh sửa ảnh miễn phí từ nguồn không chính thống.
T13	SMS Interception (TS6)	Phụ thuộc hoàn toàn vào SMS để nhận OTP thay vì dùng ứng dụng xác thực (Authenticator App) độc lập với mạng di động.
T14	Spyware (TS6)	Cho phép người khác mượn và sử dụng điện thoại không có giám sát; không bật App Lock cho các ứng dụng nhạy cảm.

Bảng 3: Bảng 3 — Lỗ Hổng Liên Quan Đến Từng Mối Đe Dọa

3.2. Nhận Xét Tổng Hợp Về Lỗ Hổng

Phân tích cho thấy hầu hết các lỗ hổng đều bắt nguồn từ **thói quen người dùng** chứ không phải từ lỗi kỹ thuật của hệ thống. Ba nhóm lỗ hổng nổi bật nhất:

- **Xác thực yếu:** Không dùng 2FA, mật khẩu đơn giản, tái sử dụng mật khẩu – xuất hiện trong 5/14 mối đe dọa.
- **Cài đặt ứng dụng thiếu cẩn thận:** Sideload APK, không kiểm tra quyền – xuất hiện trong 4/14 mối đe dọa.
- **Thiếu cấu hình bảo vệ thiết bị:** Không có màn hình khóa, thời gian tự khóa dài – ảnh hưởng trực tiếp đến truy cập vật lý trái phép.

Info

Lỗi hỏng phổ biến trong thói quen người dùng đồng nghĩa với xác suất bị khai thác cao hơn – đây là nền tảng để đánh giá Khả năng xảy ra (Likelihood) trong Phần 4.

PHẦN 4 — ĐÁNH GIÁ RỦI RO (RISK ASSESSMENT)

4.1. Bước 5 & 6 — Ma Trận Đánh Giá Rủi Ro

Mỗi mối đe dọa được đánh giá theo thang điểm:

- **Khả năng xảy ra (Likelihood):** Thấp (1) / Trung Bình (2) / Cao (3)
- **Mức độ ảnh hưởng (Impact):** Thấp (1) / Trung Bình (2) / Cao (3)
- **Mức độ rủi ro (Risk Level) = Likelihood × Impact**

4.2. Bước 7 — Phân Loại Rủi Ro

Thấp (1–2)

Rủi ro có thể chấp nhận, theo dõi định kỳ.

Trung Bình (3–4)

Cần có biện pháp xử lý trong thời gian sớm.

Cao (6–9)

Ưu tiên xử lý ngay, không chấp nhận được.

Mã	Tài Sản	Mối Đe Dọa	L	I	Risk	Phân Loại
T1	TS1 – Mạng xã hội	Account Hijacking	2	3	6	Cao
T2	TS1 – Mạng xã hội	Lộ thông tin qua privacy sai	3	2	6	Cao
T3	TS1 – Mạng xã hội	Cài đặt Fake App	2	3	6	Cao
T4	TS2 – Ngân hàng/Ví	Phishing / Smishing	3	3	9	Cao
T5	TS2 – Ngân hàng/Ví	SIM Swapping	1	3	3	Trung Bình
T6	TS2 – Ngân hàng/Ví	Trojan trên điện thoại	2	3	6	Cao
T7	TS3 – Email	Credential Stuffing	2	3	6	Cao
T8	TS3 – Email	Truy cập thiết bị bị mất	2	3	6	Cao
T9	TS4 – Danh bạ	App yêu cầu quyền danh bạ	3	2	6	Cao
T10	TS4 – Danh bạ	Đồng bộ cloud không bảo mật	2	2	4	Trung Bình
T11	TS5 – Ảnh/Video	Rò rỉ qua cloud backup	2	2	4	Trung Bình
T12	TS5 – Ảnh/Video	App chỉnh sửa ảnh độc hại	2	2	4	Trung Bình
T13	TS6 – Lịch sử chat	SMS Interception	1	3	3	Trung Bình
T14	TS6 – Lịch sử chat	Spyware	1	3	3	Trung Bình

Bảng 4: Bảng 4 — Ma Trận Đánh Giá Rủi Ro
($L = Likelihood$, $I = Impact$)

4.3. Lý Giải Điểm Số

Likelihood – Khả năng xảy ra:

- Điểm 3 (Cao): T2, T4, T9 – xảy ra thường xuyên. T2 vì cài đặt mặc định “công khai” của hầu hết nền tảng; T4 vì smishing rất phổ biến ở Việt Nam; T9 vì người dùng thường bấm “Cho phép” mà không đọc kỹ.
- Điểm 2 (Trung Bình): Đa số các mối đe dọa còn lại – cần một số điều kiện nhất định.
- Điểm 1 (Thấp): T5, T13, T14 – đòi hỏi kẻ tấn công có năng lực kỹ thuật cao hoặc cần tiếp xúc vật lý với thiết bị.

Impact – Mức độ ảnh hưởng:

- Điểm 3 (Cao): Các mối đe dọa nhắm vào TS1, TS2, TS3 – gây mất tài sản tài chính, chiếm danh tính hoặc mất quyền kiểm soát hàng loạt tài khoản.
- Điểm 2 (Trung Bình): Các mối đe dọa nhắm vào TS4 và TS5 – gây rò rỉ quyền riêng tư nhưng không dẫn đến thiệt hại tài chính trực tiếp.

4.4. Nhận Xét Tổng Hợp

Trong 14 rủi ro được đánh giá: **8 rủi ro Cao** và **6 rủi ro Trung Bình**. Không có rủi ro nào ở mức Thấp – phản ánh thực tế rằng điện thoại thông minh là mục tiêu tấn công hấp dẫn vì tập trung nhiều loại tài sản có giá trị trong một thiết bị duy nhất.

Warning

Rủi ro T4 (Phishing / Smishing) đạt mức cao nhất (9/9) và cần được ưu tiên xử lý ngay.

PHẦN 5 — XỬ LÝ RỦI RO (RISK TREATMENT)

5.1. Bước 8 & 9 — Kế Hoạch Xử Lý Rủi Ro

Với tất cả 14 rủi ro đều ở mức Trung Bình hoặc Cao, mỗi rủi ro được gán một chiến lược và biện pháp xử lý cụ thể:

- **Avoid** (Tránh): Loại bỏ hoàn toàn hành vi dẫn đến rủi ro.
- **Mitigate** (Giảm): Giảm khả năng xảy ra hoặc mức độ ảnh hưởng.
- **Transfer** (Chuyển): Chuyển giao rủi ro cho bên thứ ba.
- **Accept** (Chấp nhận): Chấp nhận rủi ro khi chi phí xử lý không tương xứng.

Mã	Rủi Ro	Mức	Chiến Lược	Biện Pháp Đề Xuất
T1	Account Hijacking	Cao	Mitigate	Bật 2FA trên tất cả tài khoản MXH; dùng password manager để tạo mật khẩu mạnh, riêng biệt cho từng dịch vụ.
T2	Lộ thông tin privacy	Cao	Mitigate	Rà soát cài đặt quyền riêng tư định kỳ (mỗi 3 tháng); chuyển hồ sơ về chế độ “Chỉ bạn bè”.
T3	Fake App	Cao	Avoid	Chỉ tải ứng dụng từ App Store / Google Play chính thức; không cài APK từ nguồn ngoài kho.
T4	Phishing / Smishing	Cao	Mitigate	Không nhấp link trong SMS/email; luôn truy cập trực tiếp website ngân hàng; kiểm tra kỹ URL trước khi nhập thông tin.
T5	SIM Swapping	TB	Mitigate	Đăng ký bảo vệ SIM với nhà mạng; dùng Authenticator App thay SMS OTP; hạn chế đăng thông tin cá nhân lên MXH.
T6	Trojan	Cao	Avoid	Không cài APK ngoài kho; bật Google Play Protect; không tải file từ Zalo/Telegram chưa xác thực nguồn gốc.
T7	Credential Stuffing	Cao	Mitigate	Dùng mật khẩu riêng biệt cho mỗi dịch vụ (password manager); bật cảnh báo đăng nhập bất thường.
T8	Truy cập thiết bị bị mất	Cao	Mitigate	Bật màn hình khóa PIN / Face ID; cài thời gian tự khóa ≤ 1 phút; bật Find My Device / Find My iPhone.
T9	App quyền danh bạ	Cao	Mitigate	Từ chối quyền danh bạ với ứng dụng không cần thiết; rà soát lại quyền đã cấp trong Cài đặt hệ thống định kỳ.
T10	Đồng bộ cloud không bảo mật	TB	Mitigate	Bật 2FA cho tài khoản Google / iCloud; đổi mật khẩu thành chuỗi mạnh dài ≥ 12 ký tự.
T11	Rò rỉ cloud backup	TB	Mitigate	Kiểm tra và giới hạn nội dung được sao lưu; lưu ảnh nhạy cảm trong album ẩn có mã khóa riêng.
T12	App chỉnh sửa ảnh độc hại	TB	Avoid	Chỉ dùng ứng dụng chỉnh sửa ảnh uy tín từ kho chính thức; cấp quyền ảnh ở mức “Chọn ảnh” thay vì “Toàn bộ thư viện”.
T13	SMS Interception	TB	Mitigate	Chuyển sang dùng Authenticator App (Google Authenticator, Authy) cho tất cả dịch vụ hỗ trợ TOTP.
T14	Spyware	TB	Mitigate	Không cho mượn điện thoại không có giám sát; bật App Lock cho ứng dụng nhạy cảm; kiểm tra ứng dụng lạ định kỳ.

Bảng 5: Bảng 5 — Kế Hoạch Xử Lý Rủi Ro

PHẦN 6 — NHẬN XÉT & TỰ ĐÁNH GIÁ

6.1. Bước 10 — Trả Lời Câu Hỏi Phản Chiếu

6.1.1. Câu 1: Rủi Ro Nào Nghiêm Trọng Nhất? Vì Sao?

Rủi ro nghiêm trọng nhất là **T4 – Phishing / Smishing** nhắm vào tài khoản ngân hàng và ví điện tử, với Risk Level = 9/9 (Likelihood 3, Impact 3) – mức tối đa trong thang đánh giá. Likelihood ở mức cao nhất vì lừa đảo qua SMS giả mạo ngân hàng đang xảy ra hằng ngày ở Việt Nam, rất dễ gặp và không đòi hỏi kỹ năng kỹ thuật cao từ phía kẻ tấn công. Impact cũng ở mức tối đa vì nạn nhân bị dẫn dụ tự cung cấp thông tin đăng nhập và OTP – kẻ tấn công có thể chuyển tiền ngay lập tức và gần như không thể thu hồi. Đây là kịch bản gây thiệt hại tài chính trực tiếp, nhanh chóng và phổ biến nhất trong thực tế hiện nay.

6.1.2. Câu 2: Nếu Không Áp Dụng Biện Pháp, Hậu Quả Có Thể Là Gì?

Nếu không áp dụng bất kỳ biện pháp xử lý rủi ro nào, hậu quả sẽ leo thang theo chuỗi. Trước tiên, tài khoản ngân hàng bị xâm phạm dẫn đến mất tiền trực tiếp và không thể hoàn lại. Tiếp theo, email bị chiếm mang theo quyền khôi phục mật khẩu của hầu hết dịch vụ khác – kẻ tấn công từ đó chiếm quyền kiểm soát toàn bộ danh tính số. Tài khoản mạng xã hội bị lợi dụng để phát tán lừa đảo đến người thân, gây thiệt hại lan rộng ra cộng đồng. Dài hạn, thông tin cá nhân bị rao bán trên dark web, làm nguyên liệu cho các cuộc tấn công tinh vi hơn trong tương lai. Một lỗ hổng không được vá có thể kéo theo hàng loạt rủi ro mới mà nạn nhân không hay biết.

6.1.3. Câu 3: Vai Trò Của Người Dùng Trong Quản Lý Rủi Ro Là Gì?

Người dùng vừa là **tuyến phòng thủ đầu tiên** vừa là **mắt xích yếu nhất** trong hệ thống an ninh thông tin. Trong bài thực hành này, hầu hết các lỗ hổng đều bắt nguồn từ thói quen hằng ngày: mật khẩu yếu, cấp quyền ứng dụng thiếu cẩn thận, không bật 2FA, hay nhấp vào link không xác thực. Công nghệ bảo mật – dù tinh vi đến đâu – chỉ phát huy hiệu quả khi người dùng sử dụng đúng cách và duy trì thói quen bảo mật nhất quán. Vì vậy, vai trò của người dùng không chỉ là nạn nhân thụ động mà phải là người chủ động: thường xuyên cập nhật kiến thức về mối đe dọa mới, rà soát cài đặt

bảo mật định kỳ, và xem an ninh thông tin là trách nhiệm cá nhân chứ không phải việc của riêng bộ phận IT hay nhà cung cấp dịch vụ.

Kết Luận

Quản lý rủi ro an ninh thông tin không phải là việc làm một lần mà là một quy trình liên tục. Từ nhận diện tài sản, xác định mối đe dọa, phân tích lỗ hổng, đánh giá mức độ rủi ro đến đề xuất biện pháp – mỗi bước đều đòi hỏi tư duy phân tích và cập nhật thường xuyên khi môi trường đe dọa thay đổi.

Thông Tin Về Báo Cáo Này

A.1 Mã Nguồn Báo Cáo

- Miêu tả: Báo cáo này được xây dựng từ mã nguồn [Typst](#), với nội dung chính được chuẩn bị từ Markdown.
- Lưu trữ tại: nhánh [IE105-TH6A](#) của repo [sam-uit/typst-report-template](#)

A.2 Mã Nguồn Nội Dung Chính

- Miêu tả: Được chuẩn bị với Markdown, trong kho của [Obsidian](#).
- Lưu trữ tại: [uit/courses/IE105/assignments/TH6A](#)

A.3 Công Cụ Sử Dụng

- [Typst](#) – Ngôn ngữ soạn thảo tài liệu khoa học, dùng để biên dịch báo cáo sang PDF.
- [Pandoc](#) – Công cụ chuyển đổi định dạng Markdown → Typst (cho các bài trước).
- [Obsidian](#) – Ứng dụng ghi chú dùng để soạn thảo nội dung Markdown.
- [Cwork \(Claude\)](#) – Trợ lý AI hỗ trợ tự động hoá quy trình soạn thảo, biên dịch và quản lý nhánh git.